

UNIVERSIDAD DISTRITAL
FRANCISCO JOSÉ DE CALDAS

Segundo Taller

Mecanismos de seguridad Informática

Juan David Orduz Sastoque, Integrante 2, Integrante 3, y Integrante 4

Ingeniería de Sistemas, Facultad de Ingeniería

Universidad Distrital Francisco José de Caldas

Mecanismos de Seguridad

14 de noviembre de 2026

Bogotá, D.C.

Nota del Autor

Trabajo académico desarrollado en un laboratorio aislado y autorizado. Las pruebas se realizan con equipos propios o máquinas virtuales, direcciones privadas y tráfico de prueba; no se genera tráfico hacia Internet, redes institucionales en producción ni direcciones de terceros.

Índice

Introducción **5**

Parte I. Análisis de casos **7**

1. Presentación y alcance **7**

2. Objetivos **7**

3. Resultados de aprendizaje **8**

4. Topología y reglas del laboratorio **8**

5. Herramientas sugeridas **9**

6. Casos críticos de trabajo **10**

6.1. Caso 1. TCP SYN Flood: indisponibilidad y agotamiento de conexiones 12

6.2. Caso 2. DNS tunneling: posible salida encubierta mediante UDP/53 22

6.3. Caso 3. Exposición de servicios HTTP, FTP y otros servicios heredados 25

6.4. Caso 4. Detección de anomalías con IA/ML en tráfico TCP/IP 38

6.5. Caso 5. TCP: resets inesperados e indicios de inyección o desincronización 40

6.6. Caso 6. UDP: reflexión/amplificación DNS, NTP o SSDP 42

6.7. Caso 7. ICMP: escaneo, payloads atípicos y posible túnel 43

6.8. Caso 8. Escaneo de puertos y fingerprinting de servicios 45

6.9. Caso 9. Priorización y correlación de alertas con IA y SIEM 47

6.10. Caso 10. Mensajería XMPP: interceptación y errores de TLS 49

7. Formato mínimo de registro por hallazgo **51**

8. Entregables de la Parte I **53**

8.1. Criterios de calidad del informe 53

Parte II. Programación **54**

9. Descripción y alcance de la solución **54**

9.1. Alcance propuesto 54

9.2. Fuera de alcance 55

10. Requisitos funcionales **55**

11. Requisitos técnicos **56**

11.1. Aplicación móvil 57

11.2. Bot en Telegram (opcional) 57

11.3. Backend y API REST 57

11.4. Mapa y visualización 58

11.5. Requisitos de seguridad y privacidad 59

12. Arquitectura de referencia **59**

13. Modelo de datos propuesto **60**

14. Plan de trabajo **61**

15. Entregables de la Parte II **61**

16. Consideraciones éticas, legales y de privacidad **62**

16.1. Principios de tratamiento 62

16.2. Prohibiciones explícitas 63

16.3. Matriz de riesgos éticos y legales 63

17. Conclusiones **64**

17.1. Conclusiones de la Parte I 64

17.2. Conclusiones de la Parte II 64

17.3. Limitaciones y trabajo futuro 64

Anexos **67**

Anexo A. Registro de evidencias y cadena de custodia 67

Anexo B. Lista de verificación de entrega 69

Anexo C. Glosario 69

Introducción

Este documento es la plantilla de trabajo del **Segundo Taller de Mecanismos de Seguridad**. Reúne, en un solo informe técnico, el análisis de diez casos de seguridad en redes IEEE 802.3 con servicios TCP/IP y el diseño de una solución de programación para el rastreo autorizado de ubicaciones. El taller se desarrolla en un laboratorio académico aislado, con equipos propios o máquinas virtuales, direcciones privadas y tráfico de prueba.

La plantilla está dividida en archivos independientes para facilitar el trabajo en equipo, la revisión por pares y el control de versiones. Cada integrante puede trabajar en su archivo sin sobrescribir el de sus compañeros; al final, todos los archivos se ensamblan en `main.tex`.

Tabla 1
Organización de la plantilla

Archivo	Contenido
`main.tex`	Preámbulo, portada, metadatos y ensamblado del documento.
`secciones/01-introduccion.tex`	Introducción, alcance, nota ética y datos del equipo.
`secciones/02-marco-parte1.tex`	Presentación, objetivos, resultados de aprendizaje, topología, reglas y herramientas.
`secciones/03-casos/`	Diez fichas de caso, una por archivo.
`secciones/04-registro-hallazgos.tex`	Formato mínimo de registro y consolidado de hallazgos.
`secciones/05-entregables-parte1.tex`	Entregables y lista de verificación de la Parte I.
`secciones/06-parte2-descripcion.tex`	Descripción y alcance de la solución de rastreo.
`secciones/07-parte2-requisitos.tex`	Requisitos funcionales, técnicos y de seguridad.
`secciones/08-parte2-arquitectura.tex`	Arquitectura de referencia, modelo de datos y plan de trabajo.
`secciones/09-parte2-etica.tex`	Consideraciones éticas, legales y de privacidad.
`secciones/10-conclusiones.tex`	Conclusiones y recomendaciones.
`secciones/11-anexos.tex`	Registro de evidencias, lista de entrega y glosario.
`referencias.bib`	Fuentes bibliográficas en formato BibLaTeX (APA 7).

Cómo usar la plantilla

- Reemplace los marcadores `Integrante 1`, `Integrante 2`, `Integrante 3` e `Integrante 4` de la portada por los nombres y códigos reales.

- Complete la Tabla 2 con los datos del equipo y la distribución de responsabilidades.
- Desarrolle cada caso en su archivo correspondiente. No elimine las preguntas de análisis: responda cada una con evidencia.
- Adjunte capturas de pantalla legibles, filtros de Wireshark, extractos de registros y, cuando aplique, el archivo PCAP de laboratorio.
- Calcule el hash SHA-256 de cada evidencia original y regístrelo en la ficha del caso y en el Anexo A.
- Verifique que todas las direcciones, nombres y credenciales estén anonimizados antes de entregar el informe.
- Cierre el documento con las conclusiones, las limitaciones de la evidencia y las referencias consultadas.

Alcance ético y legal

Este taller es un ejercicio académico. No se solicita vulnerar, atacar ni hackear sistemas, redes o personas reales. Todas las actividades de análisis se realizan sobre capturas didácticas, telemetría sintética o pruebas benignas autorizadas en un entorno aislado. El rastreo de ubicaciones de la Parte II debe operar únicamente con consentimiento informado, finalidad académica y datos anonimizados; no se permite rastrear personas sin autorización ni reutilizar la información para fines distintos de los del taller.

Datos del equipo

Tabla 2
Integrantes del equipo y distribución de responsabilidades

No.	Nombre completo	Código	Responsabilidad principal
1			
2			
3			
4			

Distribución sugerida. Una distribución equilibrada consiste en asignar los casos 1 a 3 al Integrante 1; los casos 4 y 5, junto con el backend de la Parte II, al Integrante 2; los casos 6 a 8 y la aplicación móvil al Integrante 3; y los casos 9 y 10, junto con el bot de Telegram y la integración, al Integrante 4. Todos los integrantes deben revisar la versión final y firmar la lista de verificación del Anexo B.

Parte I. Análisis de casos

1. Presentación y alcance

La práctica estudia riesgos de disponibilidad, confidencialidad e integridad en una LAN Ethernet IEEE 802.3 que transporta IPv4/IPv6 y servicios TCP/IP. El trabajo se realiza exclusivamente en equipos propios o máquinas virtuales, con direcciones privadas, tráfico de prueba y autorización expresa. No se debe generar tráfico hacia Internet, redes institucionales en producción ni direcciones de terceros.

El alcance del informe comprende el análisis de diez casos críticos, la propuesta de controles preventivos, detectivos, correctivos y de recuperación, y el diseño de una solución de programación para el rastreo autorizado de ubicaciones. Los controles se contrastan con las recomendaciones para sistemas de detección y prevención de intrusiones (Scarfone & Mell, 2007) y para el endurecimiento de servidores (Scarfone et al., 2008). Cada afirmación técnica debe sostenerse en evidencia verificable: capturas, registros, filtros, comandos, hashes y marcas de tiempo.

2. Objetivos

- Reconocer indicadores de compromiso y comportamientos anómalos en tráfico TCP, UDP, ICMP, DNS, HTTP/HTTPS y mensajería.
- Usar Wireshark y registros del sistema para correlacionar eventos, direcciones, puertos, marcas de tiempo y estados de conexión.
- Evaluar controles preventivos y detectivos: firewall, segmentación, endurecimiento de servicios, TLS, limitación de tasa e IDS/SIEM.
- Proponer el uso responsable de aprendizaje automático para priorizar alertas, sin delegar bloqueos

automáticos críticos a un modelo no validado.

- Documentar resultados reproducibles mediante capturas, filtros, registros, hashes y recomendaciones verificables.
- Diseñar, en la Parte II, una propuesta técnica y ética de una aplicación, programa o bot que permita compartir y visualizar ubicaciones con consentimiento informado.

3. Resultados de aprendizaje

- Diferencia entre síntoma, indicador, hipótesis y evidencia confirmada.
- Interpreta capturas de paquetes y registros sin confundir anomalías con prueba definitiva de ataque.
- Relaciona cada caso con controles preventivos, detectivos, correctivos y de recuperación.
- Entrega un informe técnico con hallazgos, limitaciones y un plan de mejora priorizado.

4. Topología y reglas del laboratorio

La topología sugerida es un ejemplo; se pueden usar direcciones privadas equivalentes, siempre que la red permanezca aislada y bajo control del equipo.

Tabla 3
Elementos de la topología sugerida

Elemento	Dirección / función	Recomendación
Switch Ethernet IEEE 802.3	VLAN de laboratorio	Sin conexión a la red productiva.
Equipo analista	192.168.50.10/24	Wireshark; acceso a los registros del laboratorio.
Servidor web/pruebas	192.168.50.20/24	HTTP de laboratorio o HTTPS con certificado de prueba.
Servidor DNS de laboratorio	192.168.50.53/24	Resolver solo nombres de prueba.
Servidor de mensajería (opcional)	192.168.50.30/24	XMPP en entorno aislado.
Gateway de laboratorio	192.168.50.1/24	Sin reenvío hacia Internet; filtrado habilitado.

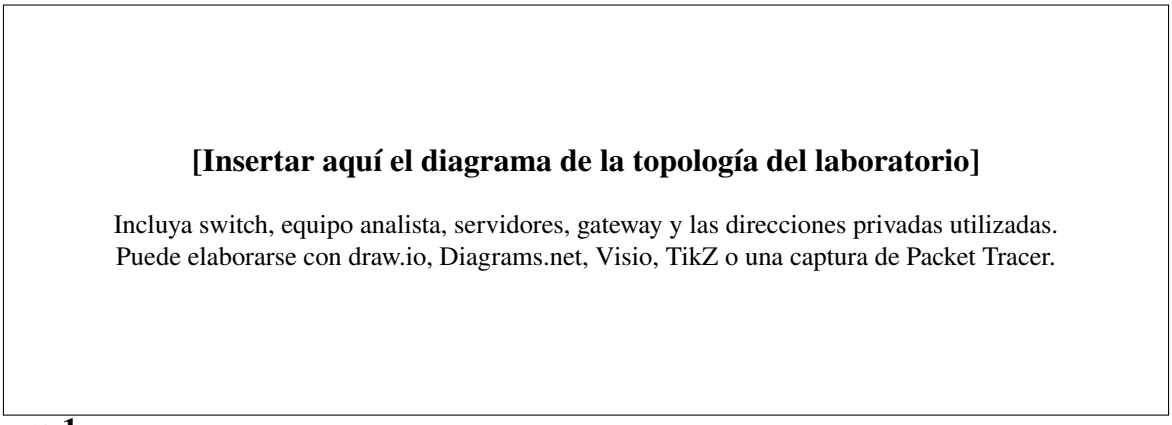


Figura 1
Topología del laboratorio

Reglas obligatorias.

- Usar exclusivamente equipos o máquinas virtuales bajo control del grupo y una VLAN o red virtual aislada.
- Generar tráfico de prueba benigno o utilizar PCAP didácticos o sintéticos. Ejecutar pruebas de DoS, exfiltración o spoofing únicamente en ambientes aislados y con autorización.
- Sincronizar los relojes de los equipos y registrar fecha, hora, IP, puerto, herramienta y versión.
- Anonimizar datos personales y credenciales; no capturar tráfico de usuarios ajenos al laboratorio.
- Guardar una copia original de cada evidencia y calcular su hash SHA-256; analizar una copia de trabajo.

5. Herramientas sugeridas

Se sugiere Wireshark; `netstat` y PowerShell en Windows; el Visor de eventos; Windows Defender Firewall; Zeek y/o Suricata cuando estén disponibles; Wazuh o un SIEM equivalente; y Python con scikit-learn para el análisis de características agregadas (Scikit-learn developers, 2026; Wireshark Foundation, 2026). Utilice herramientas y versiones aprobadas para el laboratorio y registre la versión exacta en cada ficha.

Tabla 4
Herramientas del laboratorio y registro de versiones

Herramienta	**Uso en el taller**	**Versión registrada**
Wireshark	Captura, filtrado y análisis de tráfico.	
`netstat` y PowerShell	Estado de conexiones, procesos y servicios.	
Visor de eventos	Registros del sistema operativo y de seguridad.	
Windows Defender Firewall	Reglas, registros y validación de filtrado.	
Zeek y/o Suricata	Detección de intrusiones y metadatos de flujos.	
Wazuh o SIEM equivalente	Correlación y priorización de alertas.	
Python y scikit-learn	Análisis de características agregadas y detección de anomalías.	

6. Casos críticos de trabajo

En cada caso, el equipo debe completar las tareas de observación y análisis, justificar los indicadores, proponer controles y adjuntar evidencia. Las actividades de ataque se sustituyen por análisis de PCAP, telemetría sintética o pruebas benignas autorizadas. La Tabla 5 presenta el panorama de los diez casos.

Tabla 5

Resumen de los casos críticos

Caso	Tema	Protocolo / servicio	Evidencia principal
1	TCP SYN Flood	TCP	Gráfica temporal SYN/ACK y tabla de conexiones.
2	DNS tunneling	UDP/53, DNS	Consultas filtradas y tabla por host/dominio.
3	Servicios HTTP, FTP y heredados	HTTP, FTP, otros	Inventario de servicios y matriz de riesgo.
4	Detección de anomalías con IA/ML	TCP/IP	Notebook reproducible y métricas del modelo.
5	Resets TCP e indicios de inyección	TCP	Tabla de flujos afectados y extractos de logs.
6	Reflexión y amplificación UDP	DNS, NTP, SSDP	Gráficas de paquetes y bytes por segundo.
7	ICMP: escaneo, payloads y túnel	ICMP	Dashboard por IP y tabla de tamaños/frecuencias.
8	Escaneo de puertos y fingerprinting	TCP/UDP	Lista de exposición y regla de detección.
9	Priorización de alertas con IA y SIEM	Múltiples fuentes	Pipeline y ejemplo de alerta enriquecida.
10	Mensajería XMPP y errores de TLS	XMPP, TLS	Checklist TLS y eventos anonimizados.

6.1. Caso 1. TCP SYN Flood: indisponibilidad y agotamiento de conexiones

Situación

Un servidor web de laboratorio responde lentamente o deja de aceptar nuevas conexiones.

Objetivo:

Analizar el comportamiento del establecimiento de conexiones TCP para identificar posibles indicadores de un ataque SYN Flood, mediante la inspección de paquetes de red, el análisis de conexiones y la revisión de registros del sistema.

Se busca identificar patrones anormales en las solicitudes SYN, respuestas SYN/ACK y confirmaciones ACK, así como proponer mecanismos de detección y mitigación que contribuyan a proteger la disponibilidad de los servicios de red.

Fundamento Teórico:

TCP (Transmission Control Protocol) es un protocolo de transporte orientado a conexión que utiliza un proceso de establecimiento conocido como Three-Way Handshake.

Este proceso consta de tres etapas:

- SYN: el cliente solicita establecer una conexión.
- SYN/ACK: el servidor responde aceptando la solicitud.
- ACK: el cliente confirma la respuesta y se completa el establecimiento de la conexión.

Un ataque SYN Flood busca agotar los recursos del servidor mediante el envío de numerosas solicitudes SYN que pueden quedar sin completar. Esto puede provocar una acumulación de conexiones pendientes y afectar la disponibilidad del servicio.

Procedimiento: El análisis forense y de tráfico se llevó a cabo siguiendo una serie de pasos secuenciales respaldados por las evidencias capturadas:

1. **Preparación y verificación de la captura PCAP:**

   Se verificó la integridad del archivo de captura utilizado mediante el cálculo de su huella criptográfica SHA-256 en entorno PowerShell, obteniendo el valor hash correspondiente al

archivo analizado, como se observa en la Figura 2.

2. **Identificación de paquetes SYN mediante Wireshark:**

   Se cargó el archivo `200722_tcp_anon.pcapng` en la herramienta Wireshark y se aplicó el filtro de visualización `tcp.flags.syn == 1 && tcp.flags.ack == 0` para aislar las solicitudes de inicio de conexión puras (paquetes SYN), identificando las tramas correspondientes (Figura 3).

3. **Identificación de respuestas SYN/ACK:**

   Se aplicó el filtro `tcp.flags.syn == 1 && tcp.flags.ack == 1` para localizar las respuestas del servidor aceptando las conexiones solicitadas (Figura 4).

4. **Inspección del establecimiento de conexiones y Handshake:**

   Mediante el filtro `tcp.flags.ack == 1 && tcp.flags.syn == 0`, se examinaron los paquetes de confirmación ACK y el flujo posterior de la comunicación, incluyendo intercambio de datos y cierre de sesión (Figura 5).

5. **Inspección de conversaciones TCP:**

   Se utilizó la herramienta de estadísticas de conversaciones TCP de Wireshark para analizar los flujos de comunicación entre las direcciones IP involucradas (Figura 6).

6. **Análisis temporal de solicitudes y respuestas:**

   Se emplearon las gráficas de E/S (*I/O Graphs*) de Wireshark configurando filtros específicos para tramas SYN (Figura 7) y SYN/ACK (Figura 8) con el fin de evaluar la distribución temporal del tráfico.

7. **Inspección de conexiones TCP locales:**

   Se revisó el estado de las conexiones de red del sistema mediante comandos de diagnóstico para evaluar los estados actuales de los sockets (Figura 9).

```
PS C:\WINDOWS\System32>  Get-FileHash "$HOME\Documents\GitHub\segundo-taller-mecanismos-seguridad\Capturas PCAP\Originales\200722_tcp_anon.pcapng" -Algorithm SHA256

Algorithm       Hash                                                                   Path
---------       ----                                                                   ----
SHA256          5295B16EA117FA8BB1A65418FCA81E709BEA58D3A830BC3BB5C4A2ED0466EA9C       C:\Users\Juan Orduz\Documents...
```

Figura 2

Verificación de integridad del archivo PCAP mediante el cálculo de hash SHA-256.

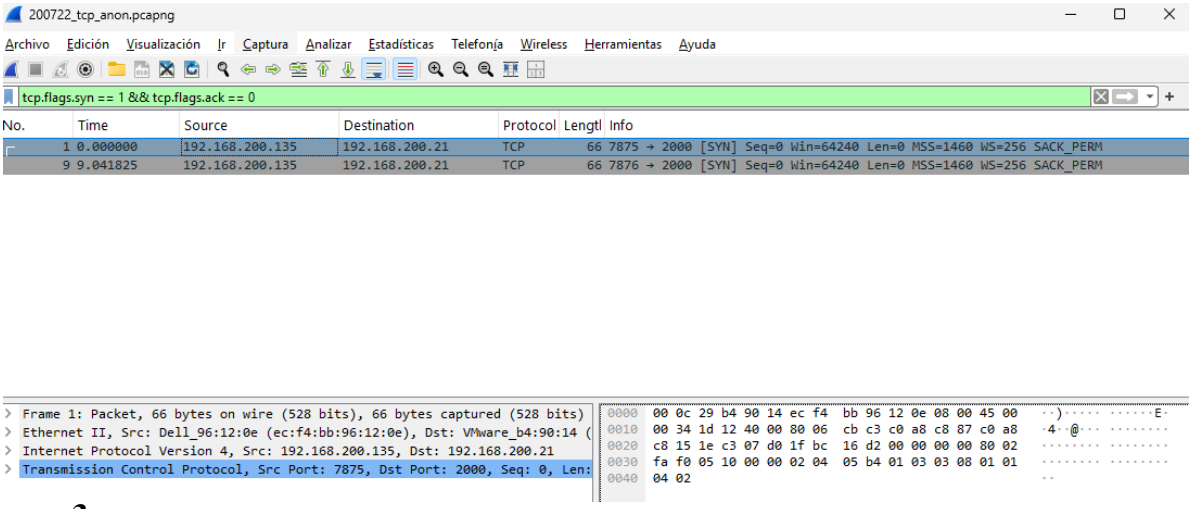


Figura 3

Filtrado de solicitudes de inicio de conexión SYN (`tcp.flags.syn == 1 && tcp.flags.ack == 0`) en Wireshark.

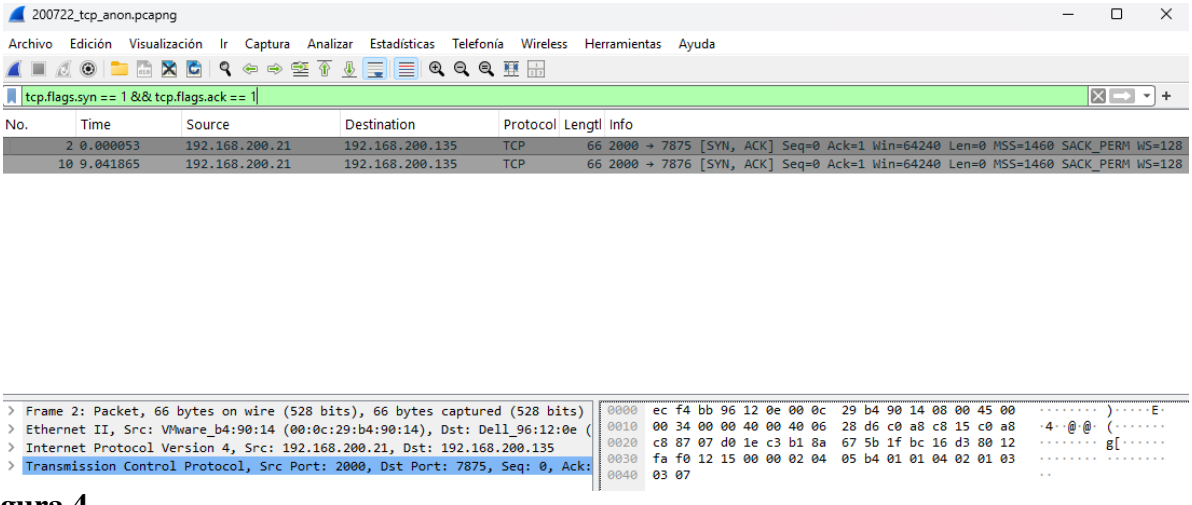


Figura 4

Identificación de respuestas SYN/ACK del servidor (`tcp.flags.syn == 1 && tcp.flags.ack == 1`).

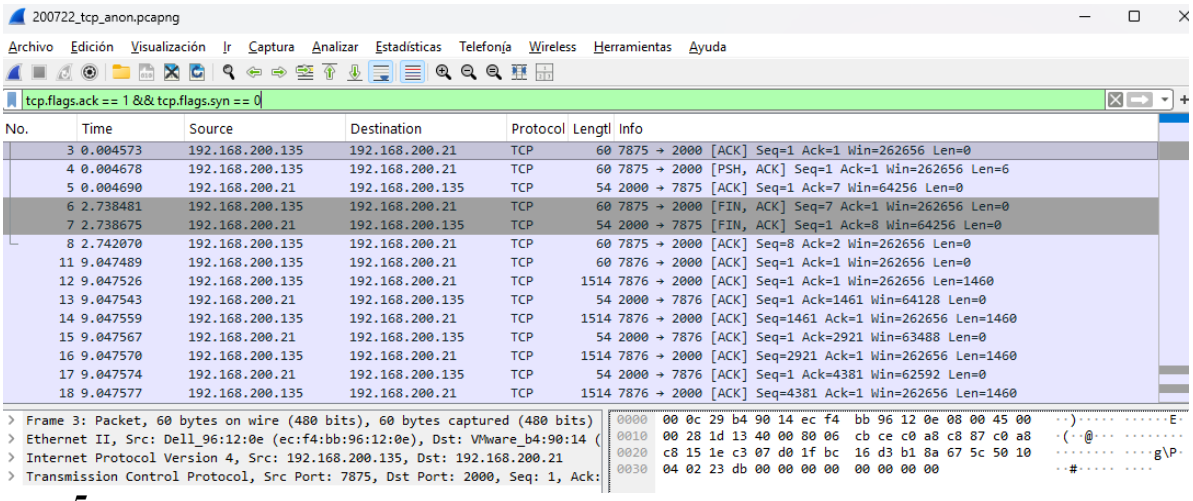


Figura 5

Inspección de paquetes ACK y tráfico posterior de la sesión TCP.

Resultados obtenidos: A partir de la inspección de las evidencias proporcionadas por las capturas de Wireshark y las herramientas del sistema, se extrajeron los siguientes resultados cuantitativos y cualitativos:

- **Análisis de paquetes SYN y SYN/ACK:** En las capturas de Wireshark se identificaron explícitamente dos solicitudes SYN principales (tramas 1 y 9) originadas desde la dirección IP `192.168.200.135` (puertos `7875` y `7876`) dirigidas al servidor `192.168.200.21` en el puerto `2000` (Figura 3). Asimismo, el servidor respondió simétricamente con dos paquetes SYN/ACK (tramas 2 y 10) hacia los mismos puertos de origen (Figura 4).

- **Conversaciones TCP:** Las estadísticas de conversaciones TCP (Figura 6) reflejan los flujos de comunicación identificados en la captura:

- **Estados de conexión locales:** La inspección mediante comandos de red (Figura 9) muestra múltiples conexiones activas asociadas a procesos del sistema, reportando predominantemente estados como `Established`, además de estados de cierre y espera como `TimeWait` y `CloseWait`, con identificadores de proceso (`OwningProcess`) numéricos específicos (ej. `14244` y `24444`).

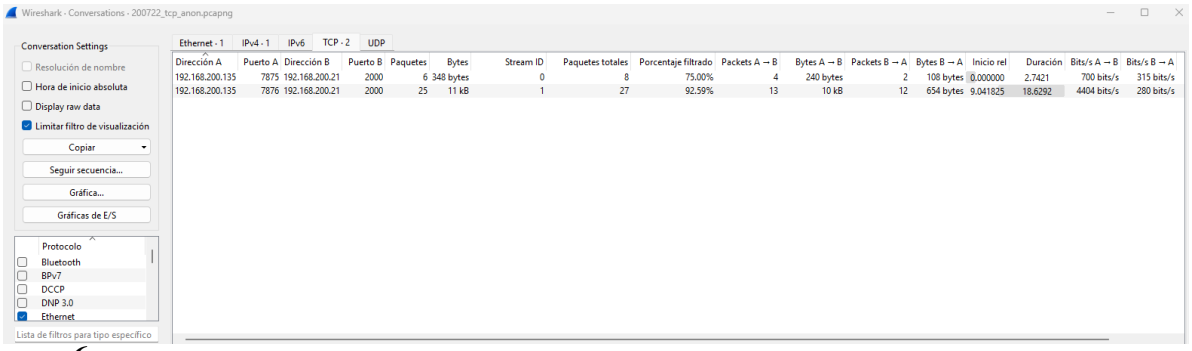


Figura 6

Estadísticas de conversaciones TCP recopiladas en Wireshark.

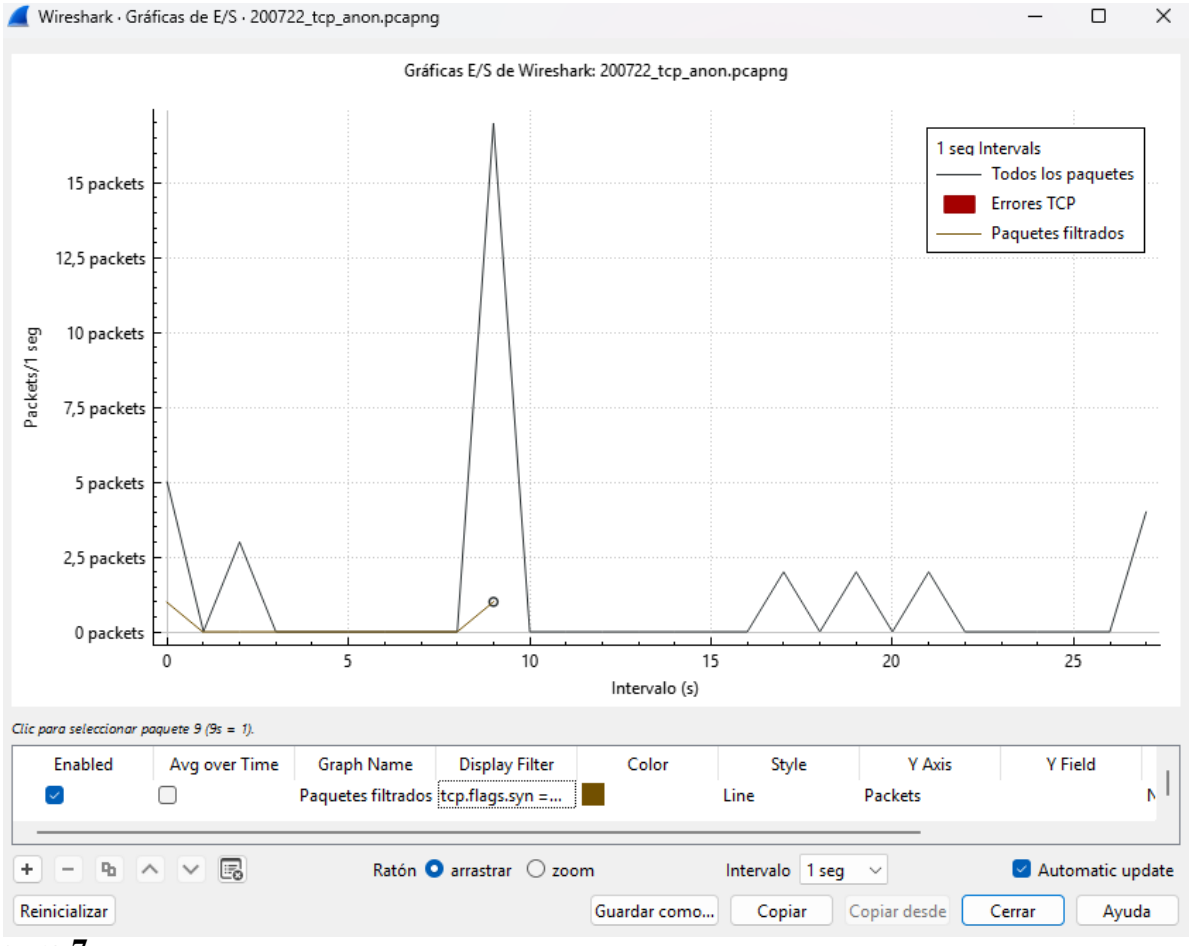


Figura 7

Gráfica de E/S de Wireshark para el análisis temporal de paquetes SYN filtrados.

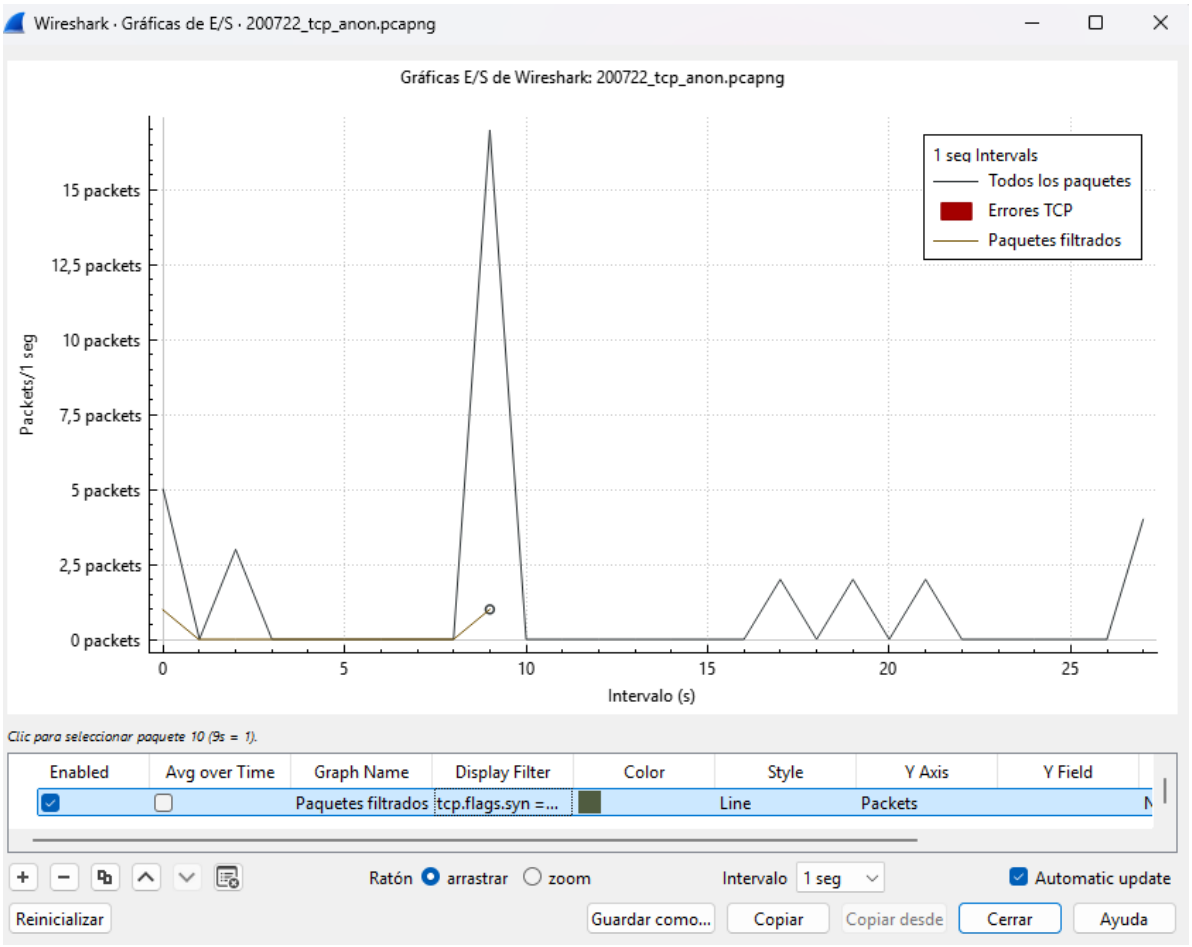


Figura 8

Gráfica de E/S de Wireshark para el análisis temporal de respuestas SYN/ACK.

Tabla 6

Tabla de conversaciones TCP extraídas de la evidencia.

IP Origen	Puerto A	IP Destino	Puerto B	Paquetes Totales	Bytes Totales	Duración (s)
192.168.200.135	7875	192.168.200.21	2000	8	348 bytes	2.7421
192.168.200.135	7876	192.168.200.21	2000	27	11 kB	18.6292

>

```
LocalAddress  : 2803:b2a0:8:74d8:13c:fa41:a514:619f
LocalPort     : 64850
RemoteAddress : 2606:4700:440b::6812:2715
RemotePort    : 443
State         : Established
OwningProcess : 14244

LocalAddress  : fe80::256b:1a3:bc12:6334%15
LocalPort     : 63889
RemoteAddress : fe80::1%15
RemotePort    : 53
State         : TimeWait
OwningProcess : 0

LocalAddress  : 2803:b2a0:8:74d8:13c:fa41:a514:619f
LocalPort     : 63818
RemoteAddress : 2a03:2880:f32f:121:face:b00c:0:167
RemotePort    : 443
State         : Established
OwningProcess : 14244

LocalAddress  : 2803:b2a0:8:74d8:13c:fa41:a514:619f
LocalPort     : 63632
RemoteAddress : 2620:117:c000:622:107:167:110:216
RemotePort    : 443
State         : Established
OwningProcess : 14244

LocalAddress  : 2803:b2a0:8:74d8:13c:fa41:a514:619f
LocalPort     : 62583
RemoteAddress : 2606:4700:440b::6812:2715
RemotePort    : 443
State         : Established
OwningProcess : 14244

LocalAddress  : 2803:b2a0:8:74d8:13c:fa41:a514:619f
LocalPort     : 62563
RemoteAddress : 2a06:98c1:3101::6812:202f
RemotePort    : 443
State         : Established
OwningProcess : 14244

LocalAddress  : 2803:b2a0:8:74d8:13c:fa41:a514:619f
LocalPort     : 62425
RemoteAddress : 2600:1419:c200:b93::ae0
RemotePort    : 443
State         : CloseWait
OwningProcess : 24444

LocalAddress  : fe80::256b:1a3:bc12:6334%15
```

Figura 9

Inspección de estados de conexiones de red locales mediante comandos de diagnóstico.

Análisis de resultados: Al contrastar las evidencias obtenidas, se observa un comportamiento normal y completado del *Three-Way Handshake* para las conexiones analizadas. Cada paquete SYN enviado por el cliente (`192.168.200.135`) obtuvo una respuesta SYN/ACK correspondiente por parte del servidor (`192.168.200.21`), seguida de los paquetes ACK correspondientes que permitieron establecer la comunicación y realizar transferencia de datos (como se visualiza en las tramas de la Figura 5 y las duraciones registradas en la Tabla 6).

Si bien las gráficas temporales de E/S (Figuras 7 y 8) muestran un pico puntual de tráfico que alcanza aproximadamente 17 paquetes por segundo en el intervalo de los 9 segundos, este incremento responde a una ráfaga legítima de intercambio de datos y cierre de conexiones, y no a una acumulación masiva de solicitudes SYN huérfanas.

Limitaciones de las evidencias: Las trazas analizadas corresponden a un escenario de tráfico controlado con un volumen reducido de transacciones entre IPs específicas; por lo tanto, las evidencias no muestran síntomas de saturación, agotamiento de recursos ni un ataque SYN Flood activo.

Indicadores de detección: A partir del análisis de las evidencias, se evalúan los siguientes indicadores de seguridad:

- **Picos de solicitudes SYN:** Observado puntualmente en la gráfica temporal (Figura 7), pero asociado a tráfico legítimo.
- **Solicitudes SYN sin completar el handshake:** No observado; todas las solicitudes contaron con su respectiva respuesta y confirmación.
- **Incremento de conexiones pendientes:** No verificado en las capturas analizadas.
- **Múltiples fuentes generando solicitudes:** No observado, el tráfico proviene de una única IP cliente (`192.168.200.135`).

- **Comportamiento temporal inusual:** Se detectó un pico temporal aislado a los 9 segundos, el cual fue verificado como parte de la transferencia normal de la sesión (Figura 6).

Regla de detección propuesta: Para la identificación temprana de anomalías de tipo SYN Flood en entornos de producción, se propone una regla conceptual basada en umbrales dinámicos respecto a la línea base del servicio:

$$\text{Alerta SYN Flood} \iff \left(\frac{\text{Conteo SYN}_{\Delta t}}{\text{Conteo SYN/ACK}_{\Delta t}} > \alpha\right) \wedge \left(\text{Conexiones}_{\text{Half-Open}} > \text{Umbral}_{\text{baseline}}\right)$$

Donde α representa el factor de proporción esperado entre solicitudes de establecimiento y respuestas del servidor, y los umbrales numéricos deben calibrarse estrictamente de acuerdo con el comportamiento histórico y la capacidad de procesamiento del servicio protegido.

Mitigación y defensa. Para garantizar la resiliencia de la infraestructura ante posibles escenarios de denegación de servicio por agotamiento de conexiones, se recomiendan las siguientes medidas técnicas:

- **Actualización de sistemas:** Mantener actualizados el sistema operativo y los servicios expuestos para parchear vulnerabilidades de pila de red.
- **Limitación de exposición:** Reducir la superficie de ataque limitando el acceso a los servicios únicamente a redes o segmentos autorizados.
- **Mecanismos de protección nativos:** Habilitar tecnologías de mitigación a nivel de sistema operativo como *SYN Cookies* para evitar el consumo de memoria en la cola de conexiones pendientes (*backlog*).
- **Control de tasa (*Rate Limiting*):** Aplicar políticas de control de tráfico en los dispositivos de borde o cortafuegos para limitar ráfagas excesivas de solicitudes SYN.
- **Monitorización continua:** Vigilar activamente el estado de las colas de conexiones y escalar incidentes al equipo de infraestructura ante anomalías sostenidas.

Es indispensable validar que la implementación de estas medidas no restrinja ni bloquee el acceso a los clientes legítimos de la red.

Preguntas de análisis.

1. **¿Qué recursos mantiene el servidor durante el handshake TCP?**

   Durante el proceso de establecimiento de conexión (*Three-Way Handshake*), el servidor web reserva recursos críticos en su pila de red. Al recibir una solicitud SYN, el núcleo del sistema operativo asigna una entrada en la cola de conexiones pendientes (*SYN backlog queue*) y crea una estructura de control de socket (*Transmission Control Block - TCB*), consumiendo memoria RAM y ciclos de procesamiento para gestionar los temporizadores de retransmisión y los números de secuencia iniciales hasta recibir la confirmación ACK final.

2. **¿Qué falsos positivos pueden producir picos legítimos?**

   Un incremento repentino en la tasa de solicitudes SYN no siempre denota actividad maliciosa. Entre los factores legítimos que pueden generar picos temporales se encuentran: la concurrencia masiva de usuarios en horarios pico, el inicio simultáneo de aplicaciones cliente, reintentos automáticos de conexión ante intermitencias temporales de la red, la ejecución de actualizaciones de software o la apertura múltiple de conexiones persistentes de tipo HTTP/2 o HTTP/3 por parte de navegadores modernos.

Conclusiones:

- Se logró analizar exitosamente el contenido del archivo de captura PCAP mediante la verificación de su integridad criptográfica y la inspección detallada de tramas en Wireshark.
- Se identificó un comportamiento TCP completamente normal y estructurado mediante el *Three-Way Handshake*, donde las solicitudes SYN enviadas por la IP `192.168.200.135` obtuvieron respuestas SYN/ACK y confirmaciones ACK válidas por parte del servidor `192.168.200.21`.

- No fue posible comprobar la existencia de indicadores de un ataque SYN Flood debido a que el volumen de tráfico analizado es reducido y no presenta conexiones huérfanas ni desproporción entre solicitudes y respuestas.
- El análisis presentó limitaciones derivadas de la naturaleza acotada de la muestra de tráfico de laboratorio, la cual carece de escala masiva.
- Se determinó la pertinencia de implementar mecanismos defensivos preventivos, tales como *SYN Cookies* y políticas de control de tasa, para proteger la disponibilidad futura ante eventuales contingencias de denegación de servicio.

Tabla 7
Ficha de registro del hallazgo. Caso 1

Campo	**Registro**
Identificador	Caso 1 (TCP SYN Flood), Evidencias 01 a 08 (`01_hash_original.png` a `08_conexiones_netstat.png`). Analista: Juan David Orduz.
Fecha y hora	Captura analizada: `200722_tcp_anon.pcapng` (datos anonimizados del 20 de julio de 2007).
Origen/destino	Tráfico observado entre el cliente `192.168.200.135` (puertos `7875`, `7876`) y el servidor `192.168.200.21` (puerto `2000`).
Observación	Análisis forense de tráfico de red en Wireshark y revisión de conexiones locales mediante consola. Se identificó un establecimiento de conexión TCP normal (*Three-Way Handshake*) sin evidencias de ataque SYN Flood.
Hipótesis	Si el servidor experimenta un ataque SYN Flood, se observará una desproporción masiva de paquetes SYN frente a SYN/ACK y una acumulación de conexiones semiconectadas (*half-open*).
Validación	Las capturas y estadísticas de Wireshark (Figuras 3 a 8) y de red (Figura 9) mostraron simetría total en el *handshake*, descartando anomalías de denegación de servicio.
Severidad	Baja / Informativa (Escenario de laboratorio con tráfico nominal controlado).
Acción	Documentar los resultados técnicos reales, descartar la hipótesis de ataque por falta de indicadores y proponer directrices de monitorización preventiva y mitigación.
Integridad	Archivo de captura validado mediante huella criptográfica SHA-256 (`5295B16EA117FA8BB1A65418FCA81E709BEA58D3A830BC3BB5C4A2ED0466EA9C`).

6.2. Caso 2. DNS tunneling: posible salida encubierta mediante UDP/53

Situación

Se observa tráfico DNS con consultas repetitivas o nombres de dominio inusualmente largos.

El DNS se define en el RFC 1035 (Mockapetris, 1987).

Procedimiento.

- Aplicar en Wireshark el filtro `udp.port == 53` y, cuando corresponda, `dns`.
- Examinar la longitud y la entropía aproximada de las etiquetas, la frecuencia, el volumen por cliente y los dominios consultados.
- Correlacionar con el resolver autorizado y los registros DNS; usar únicamente dominios de prueba o PCAP de entrenamiento.

Indicadores que deben buscarse. Subdominios largos o de alta entropía, alta frecuencia, respuestas o tamaños atípicos y destinos no habituales; verificar explicaciones legítimas como telemetría o CDN.

Mitigación y defensa. Forzar el uso de resolvers autorizados; registrar las consultas; aplicar filtrado DNS y políticas de salida; investigar el host de origen antes de bloquear.

Evidencias que se entregan. Capturas filtradas, tabla por host/dominio, hipótesis y verificación con registros.

Preguntas de análisis.

1. ¿Por qué el carácter sin conexión de UDP no significa que todo DNS sea malicioso?
2. ¿Qué atributos ayudan a distinguir una anomalía?

Tabla 8

Ficha de registro del hallazgo. Caso 2

Campo	**Registro**
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.3. Caso 3. Exposición de servicios HTTP, FTP y otros servicios heredados

Situación

El servidor presenta servicios abiertos que podrían estar innecesarios o débilmente configurados. Los riesgos de aplicaciones web se pueden contrastar con el catálogo OWASP (OWASP Foundation, 2021).

Objetivo:

Identificar y evaluar los servicios de red en un entorno de laboratorio mediante el inventario de puertos, versiones y configuraciones de seguridad. A través de este análisis, se busca detectar vulnerabilidades, protocolos inseguros o software desactualizado para proponer mitigaciones efectivas que reduzcan la superficie de exposición y protejan la infraestructura de posibles riesgos.

Fundamento Teórico:

Los servicios de red permiten el intercambio de recursos mediante protocolos y puertos específicos, pero cada puerto abierto constituye un punto de exposición cuyo riesgo real depende de su configuración, versión de software y controles de acceso. Mientras que protocolos tradicionales como HTTP (puerto 80) y FTP (puerto 21) transmiten información y credenciales sin cifrar, sus alternativas seguras como HTTPS (puerto 443) y SFTP (puerto 22) emplean cifrado para garantizar la integridad y confidencialidad de los datos. La identificación y evaluación de estos servicios, junto con otros protocolos heredados e inseguros, es fundamental para determinar su necesidad operativa y corregir configuraciones vulnerables en la infraestructura.

Procedimiento. Las actividades desarrolladas durante la práctica comprendieron:

1. **Inventario de servicios y puertos:** Se examinó el estado de los puertos TCP en escucha mediante comandos de red del sistema operativo, correlacionándolos con la lista de servicios instalados (Figuras 10 y 11).

2. **Identificación de servicios, versiones y propietarios:** Se asociaron los puertos activos con sus respectivos identificadores de proceso (PID) y servicios del sistema para determinar las

dependencias operativas y ejecutores (Figura 12).

3. **Comprobación autorizada de exposición:** Se realizaron pruebas de conectividad de alcance limitado hacia puertos específicos mediante utilidades de red nativas para verificar la accesibilidad local y el filtrado de interfaces (Figura 13).

4. **Revisión de registros de autenticación y eventos:** Se consultaron los registros de eventos de seguridad del sistema operativo para identificar intentos de inicio de sesión o anomalías de acceso (Figura 14).

5. **Verificación de cifrado y mínimo privilegio:** Se inspeccionaron las cuentas de ejecución asignadas a los servicios del sistema para evaluar el cumplimiento del principio de mínimo privilegio y el uso de credenciales de servicio (Figura 15).

6. **Evaluación de riesgos y propuesta de mitigación:** Se integraron las evidencias para ponderar la exposición de la infraestructura y estructurar recomendaciones de endurecimiento.

LocalAddress	LocalPort	State	OwningProcess
::	49677	Listen	1564
::	49668	Listen	4588
::	49667	Listen	3084
::	49666	Listen	1676
::	49665	Listen	1444
::	49664	Listen	1616
::1	42050	Listen	27256
::	33060	Listen	6228
::	7680	Listen	21812
::	5432	Listen	6964
::	3306	Listen	6228
::	445	Listen	4
::	135	Listen	1876
127.0.0.1	57539	Listen	15984
127.0.0.1	53005	Listen	2916
127.0.0.1	53000	Listen	2916
127.0.0.1	51100	Listen	19844
127.0.0.1	50100	Listen	17140
127.0.0.1	50085	Listen	13188
0.0.0.0	49677	Listen	1564
0.0.0.0	49668	Listen	4588
0.0.0.0	49667	Listen	3084
0.0.0.0	49666	Listen	1676
0.0.0.0	49665	Listen	1444
0.0.0.0	49664	Listen	1616
127.0.0.1	27339	Listen	4
127.0.0.1	22112	Listen	17804
127.0.0.1	13032	Listen	17140
127.0.0.1	13031	Listen	17140
127.0.0.1	13030	Listen	17804
127.0.0.1	11001	Listen	4964
127.0.0.1	9013	Listen	22916
127.0.0.1	9012	Listen	22916
127.0.0.1	6850	Listen	20580
127.0.0.1	6463	Listen	12200
0.0.0.0	5432	Listen	6964
0.0.0.0	5040	Listen	9512
0.0.0.0	1236	Listen	4896



Name	DisplayName
ADPSvc	Servicio de plataforma de datos agregados
ALG	Servicio de puerta de enlace de nivel de aplicación
AMD Crash Defender Service	AMD Crash Defender Service
AMD External Events Utility	AMD External Events Utility
AmdAppCompatSvc	AMD Application Compatibility Database Service
AmdPpkgSvc	AMD Provisioning Packages Service
AppIDSvc	Identidad de aplicación
Appinfo	Información de la aplicación
AppReadiness	Preparación de aplicaciones
AppXSvc	AppX Deployment Service (AppXSVC)
ApxSvc	Servicio de proxy de dispositivo de audio virtual de Windows
ArmouryCrateService	Armoury Crate Service
asus	ASUS Update Servicio (asus)
AsusCertService	ASUS Certificate Service
AsusFanControlService	AsusFanControlService
asusm	ASUS Update Servicio (asusm)
AsusROGLSLService	AsusROGLSLService Download ROGLSLoader
AsusUpdateCheck	AsusUpdateCheck
AudioEndpointBuilder	Compilador de extremo de audio de Windows
Audiosrv	Audio de Windows
Aura Wallpaper Service	Aura Wallpaper Service
autotimesvc	Hora de la red de telefonía móvil
AxInstSV	Instalador de ActiveX (AxInstSV)
BDESVC	Servicio Cifrado de unidad BitLocker
BFE	Motor de filtrado de base
BITS	Servicio de transferencia inteligente en segundo plano (BITS)
BrokerInfrastructure	Servicio de infraestructura de tareas en segundo plano
BTAGService	Servicio de puerta de enlace de audio de Bluetooth
BthAvctpSvc	Servicio AVCTP
bthserv	Servicio de compatibilidad con Bluetooth
camsvc	Servicio Administrador de funcionalidad de acceso
CDPSvc	Servicio de plataforma de dispositivos conectados
CertPropSvc	Propagación de certificados
ClickToRunSvc	Microsoft Office Click-to-Run Service
ClipSVC	Servicio de licencias del cliente (ClipSVC)
com.docker.service	Docker Desktop Service
COMSysApp	Aplicación del sistema COM+
CoreMessagingRegistrar	CoreMessaging
CryptSvc	Servicios de cifrado
DcomLaunch	Iniciador de procesos de servidor DCOM
dcsvc	Servicio de configuración (DC) declarado
defragsvc	Optimizar unidades
DeviceAssociationService	Servicio de asociación de dispositivos
DeviceInstall	Servicio de instalación de dispositivos
DevQueryBroker	Agente de detección en segundo plano de DevQuery
Dhcp	Cliente DHCP
diagsvc	Diagnostic Execution Service
DiagTrack	Experiencia del usuario y telemetría asociadas
DiscordSystemHelper	Discord System Helper
DispBrokerDesktopSvc	Servicio de directivas de pantallas
DisplayEnhancementService	Servicio de mejora de visualización

Figura 11

Inventario parcial de servicios del sistema operativo.

```
Nombre de imagen              PID Servicios
========================= ======== ============================================
System Idle Process             0 N/D
System                          4 N/D
Secure System                 188 N/D
Registry                      232 N/D
smss.exe                      788 N/D
csrss.exe                    1292 N/D
wininit.exe                  1444 N/D
services.exe                 1564 N/D
LsaIso.exe                   1608 N/D
lsass.exe                    1616 KeyIso, SamSs, VaultSvc
svchost.exe                  1748 BrokerInfrastructure, DcomLaunch, PlugPlay,
                                  Power, SystemEventsBroker
fontdrvhost.exe              1788 N/D
svchost.exe                  1876 RpcEptMapper, RpcSs
svchost.exe                  1924 LSM
svchost.exe                  1180 HvHost
svchost.exe                  1676 Schedule
svchost.exe                  1684 NcbService
svchost.exe                  2056 TimeBrokerSvc
svchost.exe                  2064 ProfSvc
svchost.exe                  2192 UserManager
svchost.exe                  2204 hidserv
svchost.exe                  2264 nsi
svchost.exe                  2392 netprofm
svchost.exe                  2448 CoreMessagingRegistrar
svchost.exe                  2644 Dnscache
svchost.exe                  2788 Dhcp
svchost.exe                  2876 hns
svchost.exe                  2884 WinHttpAutoProxySvc
svchost.exe                  3032 nvagent
svchost.exe                  2368 BFE, mpssvc
amdfendrsr.exe               3076 AMD Crash Defender Service
svchost.exe                  3084 EventLog
atiesrxx.exe                 3092 AMD External Events Utility
AsusCertService.exe          3100 AsusCertService
svchost.exe                  3296 SysMain
svchost.exe                  3304 Themes
svchost.exe                  3316 EventSystem
Memory Compression           3404 N/D
svchost.exe                  3444 SENS
svchost.exe                  3484 SharedAccess
svchost.exe                  3492 AudioEndpointBuilder
svchost.exe                  3500 FontCache
svchost.exe                  3592 DispBrokerDesktopSvc
svchost.exe                  3604 Audiosrv
svchost.exe                  3664 TextInputManagementService
svchost.exe                  3864 StateRepository
svchost.exe                  3992 DusmSvc
svchost.exe                  4000 Wcmsvc
svchost.exe                  4052 webthreatdefsvc
audiodg.exe                  4136 N/D
```

Figura 12

Asociación de nombres de imagen, PIDs y servicios en ejecución.

```
PS C:\WINDOWS\System32> Test-NetConnection -ComputerName localhost -Port 80
ADVERTENCIA: TCP connect to (::1 : 80) failed
ADVERTENCIA: TCP connect to (127.0.0.1 : 80) failed


ComputerName            : localhost
RemoteAddress           : ::1
RemotePort              : 80
InterfaceAlias          : Loopback Pseudo-Interface 1
SourceAddress           : ::1
PingSucceeded           : True
PingReplyDetails (RTT) : 0 ms
TcpTestSucceeded        : False



PS C:\WINDOWS\System32> Test-NetConnection -ComputerName localhost -Port 57539
ADVERTENCIA: TCP connect to (::1 : 57539) failed


ComputerName     : localhost
RemoteAddress    : 127.0.0.1
RemotePort       : 57539
InterfaceAlias   : Loopback Pseudo-Interface 1
SourceAddress    : 127.0.0.1
TcpTestSucceeded : True



PS C:\WINDOWS\System32> Test-NetConnection -ComputerName localhost -Port 9013
ADVERTENCIA: TCP connect to (::1 : 9013) failed


ComputerName     : localhost
RemoteAddress    : 127.0.0.1
RemotePort       : 9013
InterfaceAlias   : Loopback Pseudo-Interface 1
SourceAddress    : 127.0.0.1
TcpTestSucceeded : True



PS C:\WINDOWS\System32> Test-NetConnection -ComputerName localhost -Port 139
ADVERTENCIA: TCP connect to (::1 : 139) failed
ADVERTENCIA: TCP connect to (127.0.0.1 : 139) failed


ComputerName            : localhost
RemoteAddress           : ::1
RemotePort              : 139
InterfaceAlias          : Loopback Pseudo-Interface 1
SourceAddress           : ::1
PingSucceeded           : True
PingReplyDetails (RTT) : 0 ms
```

Figura 13

Comprobación autorizada de alcance limitado para la conectividad de puertos.

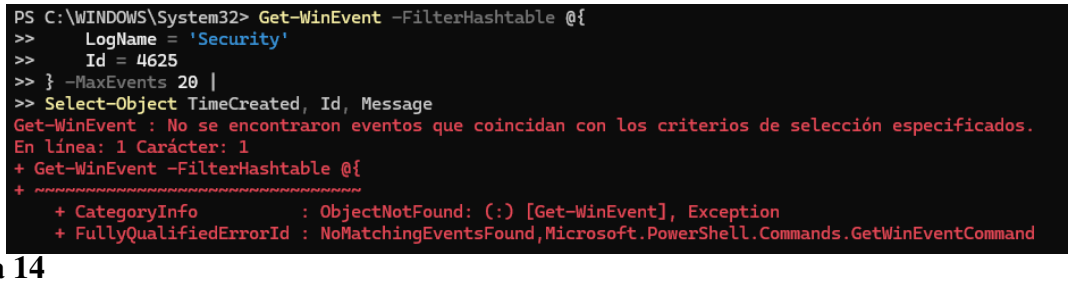


Figura 14

Consulta de registros de eventos de autenticación y seguridad.

```
PS C:\WINDOWS\System32> Get-CimInstance Win32_Service |
>> Select-Object Name, StartName, State |
>> Format-Table -AutoSize

Name                                    StartName                   State
----                                    ---------                   -----
ADPSvc                                  NT AUTHORITY\LocalService   Stopped
ALG                                     NT AUTHORITY\LocalService   Stopped
AMD Crash Defender Service              LocalSystem                 Running
AMD External Events Utility             LocalSystem                 Running
AmdAppCompatSvc                         LocalSystem                 Stopped
AmdPpkgSvc                              LocalSystem                 Running
AppIDSvc                                NT Authority\LocalService   Stopped
Appinfo                                 LocalSystem                 Running
AppReadiness                            LocalSystem                 Stopped
AppXSvc                                 LocalSystem                 Running
ApxSvc                                  NT AUTHORITY\LocalService   Stopped
ArmouryCrateService                     LocalSystem                 Running
asus                                    LocalSystem                 Stopped
AsusCertService                         LocalSystem                 Running
AsusFanControlService                   LocalSystem                 Running
asusm                                   LocalSystem                 Stopped
AsusROGLSLService                       LocalSystem                 Stopped
AsusUpdateCheck                         LocalSystem                 Running
AudioEndpointBuilder                    LocalSystem                 Running
Audiosrv                                NT AUTHORITY\LocalService   Running
Aura Wallpaper Service                  LocalSystem                 Running
autotimesvc                             NT AUTHORITY\LocalService   Stopped
AxInstSV                                LocalSystem                 Stopped
BDESVC                                  localSystem                 Stopped
BFE                                     NT AUTHORITY\LocalService   Running
BITS                                    LocalSystem                 Stopped
BrokerInfrastructure                    LocalSystem                 Running
BTAGService                             NT AUTHORITY\LocalService   Stopped
BthAvctpSvc                             NT AUTHORITY\LocalService   Stopped
bthserv                                 NT AUTHORITY\LocalService   Running
camsvc                                  LocalSystem                 Running
CDPSvc                                  NT AUTHORITY\LocalService   Running
CertPropSvc                             LocalSystem                 Stopped
ClickToRunSvc                           LocalSystem                 Running
ClipSVC                                 LocalSystem                 Stopped
com.docker.service                      LocalSystem                 Stopped
COMSysApp                               LocalSystem                 Stopped
CoreMessagingRegistrar                  NT AUTHORITY\LocalService   Running
CryptSvc                                NT Authority\NetworkService Running
DcomLaunch                              LocalSystem                 Running
dcsvc                                   LocalSystem                 Stopped
defragsvc                               localSystem                 Stopped
DeviceAssociationService                LocalSystem                 Running
DeviceInstall                           LocalSystem                 Stopped
DevQueryBroker                          LocalSystem                 Stopped
Dhcp                                    NT Authority\LocalService   Running
diagsvc                                 LocalSystem                 Stopped
```

Figura 15

Revisión de cuentas de inicio y privilegios asociados a los servicios del sistema.

Resultados obtenidos: A partir del análisis de las evidencias gráficas, se obtuvieron los siguientes resultados concretos:

- **Puertos en estado LISTEN:** Se identificaron múltiples puertos activos en escucha (Figura 10), destacando conexiones ligadas a interfaces `127.0.0.1`, `::1`, `0.0.0.0`, `::`, así como interfaces específicas como `192.168.101.16` y `172.31.144.1` en el puerto `139` (asociado al proceso PID `4`).

- **Servicios y procesos asociados:** La correlación de PIDs (Figura 12) permitió identificar servicios del núcleo y componentes de virtualización o soporte (ej. `svchost.exe`, `lsass.exe`), sin evidencias visuales directas de la ejecución de servidores web HTTP o FTP tradicionales en las trazas expuestas.

- **Comprobación de exposición:** Las pruebas mediante `Test-NetConnection` (Figura 13) mostraron fallos de conexión (`TcpTestSucceeded : False`) al intentar alcanzar puertos como el `80` y el `139` en bucle local (`::1`), mientras que otros puertos internos respondieron de forma local.

- **Eventos de autenticación:** La consulta al registro de eventos de seguridad buscando el Id `4625` (inicios de sesión fallidos) arrojó el mensaje de error *"No se encontraron eventos que coincidan con los criterios de selección especificados"* (Figura 14), lo que indica ausencia de registros bajo ese filtro en el momento de la captura.

- **Cuentas de ejecución y privilegios:** La inspección de instancias de servicio (Figura 15) evidenció que una gran proporción de los servicios del sistema operan bajo cuentas altamente privilegiadas como `LocalSystem`, mientras que otros utilizan cuentas de servicio restringidas como `NT AUTHORITY\LocalService` o `NT AUTHORITY\NetworkService`.

Tabla 9

Inventario de servicios expuestos

Puerto	Servicio	Versión	¿Necesario?	Propietario	Riesgo / observación
139	NetBIOS Session	v4.0 / Heredado	**No** (Heredado)	Sistema (4)	Expuesto en interfaces `192.168.101.16` y `172.31.144.1`; riesgo potencial de enumeración SMB/NetBIOS si hay acceso externo no filtrado.
445	SMB (Direct Hosting)	SMBv2 / SMBv3	**Solo Local**	Sistema (4)	Escucha en interfaces comodín (`::` y `0.0.0.0`); requiere validación de reglas de firewall perimetral y limitar el acceso externo.
3306 / 33060	MySQL / X Protocol	v8.0.x (Community)	**Sí** (Condicional)	No determinado	Escucha configurada en interfaces de bucle invertido y local (`::`), limitando el riesgo de acceso externo directo.

Inventario de servicios expuestos:

Análisis de seguridad e indicadores: Se evaluaron los indicadores de la guía frente a las evidencias:

1. **Servicios expuestos sin necesidad:** No determinado de forma concluyente; aunque existen puertos en escucha, la mayoría se restura a interfaces de loopback o requiere validación de firewall. El puerto `139` muestra enlace en interfaces de red específicas.

2. **Software sin soporte o desactualizado:** No fue posible determinar versiones específicas de software a partir de las capturas disponibles.

3. **Intentos de autenticación fallidos:** No se identificó evidencia de eventos fallidos debido a que la consulta de seguridad no retornó registros coincidentes (Figura 14).

4. **Uso de protocolos en texto claro:** No determinado con las capturas analizadas, ya que no se interceptó tráfico de aplicación HTTP/FTP.

5. **Configuraciones por defecto:** No determinado; se observa predominio de servicios nativos del sistema operativo bajo cuentas predeterminadas.

Tabla 10
Matriz de riesgo y criticidad del Caso 3

Identificador	Elemento	Hallazgo	Impacto	Probab.	Riesgo	Justificación
C3-H01	Puertos SMB / NetBIOS (139, 445)	Escucha en interfaces de red secundarias e IP comodín.	Medio	Bajo	Medio	La exposición de servicios SMB en redes corporativas puede facilitar ataques lateralización si no hay filtrado perimetral estricto.
C3-H02	Cuentas de Servicios	Uso extendido de la cuenta `LocalSystem` en múltiples servicios.	Alto	Bajo	Medio	Incrementa el radio de impacto en caso de que un servicio sufra un compromiso de ejecución de código.

Matriz de riesgo y criticidad:

Tabla 11
Plan de remediación y defensa propuesto

Hallazgo / Riesgo	**Acción recomendada**	**Prioridad**	**Responsable**	**Verificación**
Exposición de puertos SMB (139/445)	Restringir el tráfico SMB mediante reglas de firewall local y perimetral, bloqueando el acceso desde redes no confiables.	Media	Adm. de Infraestructura	Escaneo de puertos local/remoto (`nmap`).
Privilegios excesivos en servicios	Auditar y migrar servicios ejecutados bajo `LocalSystem` hacia cuentas de servicio con privilegios mínimos (`NetworkService` o cuentas dedicadas).	Media	Adm. de Sistemas	Revisión de configuraciones de servicios (`Get-CimInstance`).

Plan de remediación y defensa:

Preguntas de análisis:

1. **¿Cómo se prioriza un puerto abierto?**

   La priorización no depende únicamente del número del puerto, sino de una evaluación integral que incluye: el servicio de red subyacente asociado, su necesidad operativa real para el negocio, la accesibilidad de la interfaz de red donde escucha (loopback frente a interfaz pública), la versión del software, la existencia de vulnerabilidades conocidas publicadas, los mecanismos de autenticación y cifrado soportados, y el impacto potencial que tendría una explotación exitosa sobre la confidencialidad, integridad y disponibilidad del sistema.

2. **¿Qué diferencia hay entre exposición, vulnerabilidad y explotación?**

   Exposición describe la condición en la cual un servicio o puerto se encuentra accesible o disponible a través de una interfaz de red o sistema operativo. *Vulnerabilidad* representa una debilidad o fallo técnico específico en la implementación o configuración del servicio

que puede ser aprovechado. *Explotación* es la fase activa donde un atacante utiliza dicha vulnerabilidad para quebrantar los controles de seguridad y lograr un acceso o efecto no autorizado. Por ejemplo, un servidor con el puerto HTTP abierto está *expuesto*; si el software web contiene un desbordamiento de búfer sin parches, posee una *vulnerabilidad*; y si un script malicioso utiliza ese fallo para inyectar código, se ha concretado una *explotación*.

Conclusiones:

- Se logró realizar el inventario de puertos en estado de escucha y de los servicios del sistema operativo disponibles en el entorno evaluado, identificando enlaces en interfaces de bucle local, comodín y algunas direcciones de red específicas como el puerto `139`.
- Se comprobó que el alcance de la exposición de ciertos puertos está limitado a nivel de interfaces locales, aunque se detectó la necesidad de mantener un control estricto mediante cortafuegos para evitar accesos no autorizados.
- La revisión de los registros de autenticación y eventos no arrojó trazas de eventos de error de inicio de sesión bajo los filtros consultados, limitando la detección de anomalías de acceso activo en las evidencias analizadas.
- Se evidenció que gran parte de los servicios del sistema operan bajo la cuenta `LocalSystem`, lo que destaca una oportunidad de mejora en la aplicación del principio de mínimo privilegio.
- Las evidencias disponibles presentaron limitaciones para determinar versiones de software específicas o el uso de protocolos cifrados, por lo que se recomienda complementar la evaluación con escaneos de vulnerabilidades y auditorías de configuración avanzadas.

Tabla 12
Ficha de registro del hallazgo. Caso 3

Campo	Registro
Identificador	C3-H01
Fecha y hora	No especificada en las evidencias de consola proporcionadas.
Origen/destino	Local / Interfaces de red locales (`192.168.101.16`, `172.31.144.1`) y bucle invertido (`127.0.0.1`, `::1`).
Observación	Presencia de puertos en estado `LISTEN` asociados a servicios de red y del sistema operativo, incluyendo puertos NetBIOS (139) y SMB (445).
Hipótesis	Si los puertos de administración o servicios heredados están accesibles desde interfaces externas sin control de firewall, se incrementa la superficie de ataque ante intrusiones.
Validación	Respaldado por el inventario de puertos en escucha obtenido mediante comandos del sistema (Figura 10).
Severidad	Media.
Acción	Aplicar filtrado de puertos perimetral, restringir servicios innecesarios y verificar la directiva de minimización de privilegios.
Integridad	Imágenes fuente: `01_puertos_escucha.png`, `02_servicios_sistema.png`, `03_identificacion_servicios.png`, `04_comprobacion_exposicion.png`, `05_eventos_autenticacion.png`, `06_cuentas_privilegios.png`. (Hashes SHA-256 no suministrados).

Ficha de registro del hallazgo. Caso 3.

6.4. Caso 4. Detección de anomalías con IA/ML en tráfico TCP/IP

Situación

El equipo debe proponer una defensa inteligente que identifique desviaciones frente al tráfico normal.

Procedimiento.

- Crear un conjunto de datos con PCAP didácticos o tráfico benigno de laboratorio y características agregadas: conexiones por minuto, bytes por flujo, duración, flags TCP y proporción petición/respuesta.

- Separar los datos de entrenamiento y evaluación por tiempo o por sesión para evitar fuga de información.
- Comparar una línea base estadística con un detector de anomalías; documentar precisión, falsos positivos y límites. Se puede usar scikit-learn como referencia (Scikit-learn developers, 2026).
- Anonimizar los ejemplos y proteger los datos de entrenamiento.

Indicadores que deben buscarse. Desviación sostenida respecto a la línea base; puntuación de anomalía alta que debe investigarse junto con evidencia de red y registros.

Mitigación y defensa. Mantener revisión humana; monitorizar la deriva del modelo; no usar la salida de un prototipo como única razón para bloquear; proteger los datos de entrenamiento.

Evidencias que se entregan. Notebook o script reproducible, definición de atributos, métricas, matriz de confusión si hay etiquetas y ejemplos anonimizados.

Preguntas de análisis.

1. ¿Cómo afectan el desbalance de clases y los cambios legítimos de carga?
2. ¿Qué métrica es más útil para este caso?

Tabla 13
Características agregadas para el detector de anomalías

Característica	Definición operativa	Unidad	Ventana
Conexiones por minuto		conexiones/min	
Bytes por flujo		bytes	
Duración del flujo		segundos	
Flags TCP		conteo	
Proporción petición/respuesta		razón	

Tabla 14
Ficha de registro del hallazgo. Caso 4

Campo	Registro
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.5. Caso 5. TCP: resets inesperados e indicios de inyección o desincronización

Situación

Las aplicaciones reportan sesiones TCP que terminan abruptamente o se reinician de forma repetida.

Procedimiento.

- En una PCAP de laboratorio, filtrar `tcp.flags.reset == 1` y correlacionar marcas de tiempo, endpoints y sesiones.
- Examinar si los RST coinciden con cierres legítimos, reinicios de servicio, firewall o pérdida de conectividad.

- Correlacionar con registros de Zeek/Suricata y registros de aplicación, si están instalados.

Indicadores que deben buscarse. RST fuera de contexto, frecuencia inusual, sesiones truncadas o inconsistencias que requieren correlación; no inferir MITM solo por observar RST.

Mitigación y defensa. Usar TLS correctamente validado; segmentar la red; actualizar los endpoints; activar detección IDS y revisar rutas y dispositivos intermedios.

Evidencias que se entregan. Tabla de flujos afectados, extractos de registros, tiempos y hash SHA-256 de la PCAP.

Preguntas de análisis.

1. ¿Qué causas benignas generan RST?

2. ¿Qué evidencia adicional haría más sólida la hipótesis de manipulación?

Tabla 15
Ficha de registro del hallazgo. Caso 5

Campo	Registro
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.6. Caso 6. UDP: reflexión/amplificación DNS, NTP o SSDP

Situación

El servidor o gateway registra un volumen inusual de respuestas UDP, posiblemente desproporcionado respecto de las solicitudes.

Procedimiento.

- Examinar el volumen por protocolo, origen, destino y ventana temporal; distinguir el tráfico esperado de las respuestas no solicitadas.
- Revisar la configuración de los servicios propios y confirmar que no actúan como reflectores abiertos.
- No generar tráfico de amplificación: usar PCAP de entrenamiento o contadores agregados simulados.

Indicadores que deben buscarse. Gran volumen de respuestas, asimetría entre peticiones y respuestas, puertos inesperados y destinos no relacionados con las solicitudes observadas.

Mitigación y defensa. Deshabilitar servicios innecesarios; restringir las consultas recursivas DNS; aplicar limitación de tasa y filtrado anti-spoofing en la infraestructura administrada.

Evidencias que se entregan. Gráficas de paquetes y bytes por segundo, inventario de servicios y controles recomendados.

Preguntas de análisis.

1. ¿Cómo se diferencia una ráfaga legítima de un patrón de reflexión?
2. ¿Qué controles corresponden al servidor y cuáles al proveedor de red?

Tabla 16
Ficha de registro del hallazgo. Caso 6

Campo	Registro
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.7. Caso 7. ICMP: escaneo, payloads atípicos y posible túnel

Situación

Se observa una tasa de ICMP mayor de lo habitual o paquetes con tamaños o patrones repetitivos.

ICMP se especifica en el RFC 792 (Postel, 1981).

Procedimiento.

- En Wireshark, filtrar `icmp` y agrupar por IP de origen/destino, tipo, código, longitud y tiempo.
- Establecer una línea base de ping de diagnóstico legítimo y compararla con la captura analizada.
- Usar PCAP sintético o didáctico para estudiar payloads; no transmitir información sensible por ICMP.

Indicadores que deben buscarse. Ráfagas de echo request/reply, longitudes inusuales, periodicidad repetitiva o volumen no explicado por tareas de diagnóstico.

Mitigación y defensa. Permitir solo los tipos ICMP necesarios para la operación y el diagnóstico; aplicar límites proporcionados; monitorizar sin bloquear indiscriminadamente mensajes requeridos por la red.

Evidencias que se entregan. Dashboard por IP, filtro aplicado, tabla de tamaños y frecuencias, y propuesta de regla.

Preguntas de análisis.

1. ¿Qué funciones legítimas cumple ICMP?

2. ¿Qué impacto tendría bloquearlo completamente?

Tabla 17
Distribución de tráfico ICMP por tipo y longitud

Tipo	Código	Longitud	Origen	Destino	Frecuencia / observación

Tabla 18
Ficha de registro del hallazgo. Caso 7

Campo	Registro
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.8. Caso 8. Escaneo de puertos y fingerprinting de servicios

Situación

Los registros muestran intentos secuenciales contra varios puertos o servicios no habituales.

Procedimiento.

- Analizar los registros del firewall/IDS y una PCAP autorizada; contar destinos y puertos únicos por origen y periodo.
- Correlacionar eventos de Zeek y Suricata, si están disponibles.
- Elaborar una lista de exposición de los servicios propios, sin sondear redes ajenas.

Indicadores que deben buscarse. Conexiones a muchos puertos en poco tiempo, intentos repetidos a servicios inexistentes y consultas de banner o versiones no habituales.

Mitigación y defensa. Reducir la superficie expuesta; filtrar por necesidad; actualizar los servicios; alertar ante patrones repetidos y aplicar bloqueo temporal con revisión.

Evidencias que se entregan. Lista de indicadores, puertos y servicios expuestos, regla de detección y plan de endurecimiento.

Preguntas de análisis.

1. ¿Qué limitaciones tiene atribuir un escaneo a una sola IP?

2. ¿Cómo se reducen los falsos positivos por monitoreo autorizado?

Tabla 19
Lista de exposición de servicios propios

Puerto	Servicio	Versión	¿Expuesto?	Justificación	Control propuesto

Tabla 20
Ficha de registro del hallazgo. Caso 8

Campo	Registro
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.9. Caso 9. Priorización y correlación de alertas con IA y SIEM

Situación

El centro de monitoreo recibe múltiples alertas que deben agruparse y priorizarse.

Procedimiento.

- Normalizar eventos de firewall, servidor, Zeek/Suricata y sistema operativo; eliminar duplicados sin perder trazabilidad.
- Definir características agregadas por host y ventana temporal, y probar un detector de anomalías con datos controlados.
- Usar un LLM únicamente para resumir alertas anonimizadas y sugerir el triage; verificar toda

recomendación contra la evidencia.

Indicadores que deben buscarse. Alertas correlacionadas por host/tiempo, puntuación de riesgo explicable y señales convergentes en varias fuentes.

Mitigación y defensa. Revisión humana antes de acciones disruptivas; control de acceso a los registros; evaluación de sesgo y deriva; registro de decisiones y posibilidad de reversión.

Evidencias que se entregan. Diagrama del pipeline, ejemplo de alerta enriquecida, criterios de prioridad y registro de validación humana.

Preguntas de análisis.

1. ¿Cómo explicar una alerta a un analista?

2. ¿Qué riesgo supone automatizar bloqueos basados solo en una puntuación?

Tabla 21
Fuentes de eventos del pipeline de correlación

Fuente	Tipo de evento	Formato	Responsable
Firewall			
Servidor web			
Zeek / Suricata			
Sistema operativo			
SIEM / Wazuh			

Tabla 22
Ficha de registro del hallazgo. Caso 9

Campo	Registro
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

6.10. Caso 10. Mensajería XMPP: interceptación y errores de TLS

Situación

Se investiga si la comunicación entre clientes y servidor de mensajería está correctamente protegida. XMPP se especifica en el RFC 6120 y TLS 1.3 en el RFC 8446 (Rescorla, 2018; Saint-Andre, 2011).

Procedimiento.

- En un servidor XMPP de laboratorio (por ejemplo, Openfire o ejabberd), revisar la configuración TLS, los certificados, los nombres, la vigencia y la cadena de confianza.
- Capturar metadatos de conexión en una prueba autorizada y verificar que el contenido de una

sesión cifrada no se trate como texto legible.

- Revisar los registros del servidor en busca de errores de negociación, certificados inválidos o conexiones inesperadas.

Indicadores que deben buscarse. Certificados vencidos o no confiables, negociación insegura, servicios de administración expuestos o patrones de conexión que no coinciden con el uso esperado.

Mitigación y defensa. Exigir TLS robusto y validación de certificados; limitar las interfaces administrativas; mantener el servidor actualizado; aplicar cifrado de extremo a extremo (E2EE) cuando el modelo de amenaza lo requiera.

Evidencias que se entregan. Checklist TLS, eventos anonimizados, evidencia de configuración y plan de corrección.

Preguntas de análisis.

1. ¿Qué protege TLS y qué no protege?

2. ¿En qué se diferencia el cifrado de transporte del cifrado de extremo a extremo?

Tabla 23
Checklist de configuración TLS del servidor XMPP

Verificación	**Resultado**	**Evidencia / observación**
Vigencia del certificado		
Coincidencia del nombre (CN/SAN)		
Cadena de confianza completa		
Versión de TLS negociada		
Suites de cifrado permitidas		
Interfaz administrativa restringida		
Cifrado de extremo a extremo (E2EE)		
Errores de negociación en los registros		

Tabla 24
Ficha de registro del hallazgo. Caso 10

Campo	Registro
Identificador	
Fecha y hora	
Origen/destino	
Observación	
Hipótesis	
Validación	
Severidad	
Acción	
Integridad	

7. Formato mínimo de registro por hallazgo

Cada hallazgo debe registrarse con los campos de la Tabla 25. El registro separa el hecho observado de la interpretación y exige indicar la evidencia que permitió validar o descartar la hipótesis. El formato es obligatorio para los diez casos y se complementa con la ficha de cada caso.

Tabla 25
Formato mínimo de registro por hallazgo

Campo	Qué registrar
Identificador	Caso, número de evidencia y nombre del analista.
Fecha/hora	Marca temporal y zona horaria; sincronización conocida.
Origen/destino	IP, MAC cuando sea pertinente, puertos y protocolo; anonimizar si aplica.
Observación	Hecho directamente observado, sin conclusiones prematuras.
Hipótesis	Explicación posible y alternativas benignas consideradas.
Validación	PCAP o registro consultado, filtro, comandos de inspección y resultado.
Severidad	Impacto, probabilidad y justificación.
Acción	Medida propuesta, responsable, riesgo de falsos positivos y verificación.
Integridad	Nombre de archivo, tamaño y hash SHA-256 de la evidencia original.

Consolidado de hallazgos. Use la Tabla 26 para mantener la trazabilidad entre los casos y el informe final. Los hashes y la cadena de custodia se registran en el Anexo A.

Tabla 26
Consolidado de hallazgos de la Parte I

No.	Caso	Fecha/hora	Origen/destino	Observación	Severidad	Acción

Regla de evidencia

Una anomalía no es una prueba de ataque. Antes de asignar severidad, confirme la observación con al menos dos fuentes independientes (por ejemplo, PCAP y registro del servidor) y documente las explicaciones benignas que no se pudieron descartar. Si la evidencia es insuficiente, indíquelo como limitación. La conservación y el análisis de la evidencia siguen las recomendaciones de gestión de incidentes de Cichonski et al. (2012).

8. Entregables de la Parte I

El equipo debe entregar un informe técnico con los siguientes componentes. Marque cada entregable cuando esté completo y verificable.

- ☐ Informe técnico por equipo, con resumen ejecutivo y alcance del laboratorio.
- ☐ Diez fichas de caso con indicadores, análisis, hipótesis alternativas y medidas de defensa.
- ☐ Capturas de pantalla legibles y PCAP didácticas o sintéticas cuando corresponda, con hash SHA-256.
- ☐ Reglas de detección propuestas y justificadas; no se exige activar bloqueos automáticos en producción.
- ☐ Conclusiones sobre los límites de la evidencia y oportunidades de mejora.
- ☐ Anexo de evidencias con nombre de archivo, tamaño, fecha y hash SHA-256.
- ☐ Tabla de distribución del trabajo y lista de verificación firmada por los cuatro integrantes.

8.1. Criterios de calidad del informe

- **Reproducibilidad:** cada resultado debe poder repetirse con el filtro, comando o script indicado.
- **Trazabilidad:** toda afirmación debe remitir a una evidencia identificada y a una marca de tiempo.
- **Legibilidad:** las capturas deben permitir leer direcciones, puertos, filtros y marcas de tiempo.
- **Anonimización:** no deben aparecer datos personales, credenciales ni direcciones de terceros.
- **Integridad:** la evidencia original se conserva sin modificaciones y se analiza sobre una copia de trabajo.
- **Postura crítica:** se deben reconocer los falsos positivos, las limitaciones y las hipótesis no confirmadas.

Parte II. Programación

9. Descripción y alcance de la solución

La Parte II propone una aplicación, programa o bot que permita registrar un número telefónico, solicitar la ubicación del dispositivo asociado y visualizarla en un mapa, en tiempo real o por intervalos. La solución debe operar con consentimiento informado del usuario y con datos anonimizados; el objetivo es académico y no comercial.

Tabla 27
Niveles de viabilidad del rastreo según el servicio

Servicio	Fuente de ubicación	Viabilidad y límites	Requisito de consentimiento
WhatsApp	Ubicación compartida manualmente	Limitada e indirecta: la aplicación no expone la ubicación en tiempo real ni permite rastrear a un contacto sin su acción.	El usuario debe compartir su ubicación de forma explícita.
Telegram	Bot y ubicación enviada por el usuario	Un bot puede solicitar la ubicación mediante botones, pero no puede rastrear automáticamente sin que el usuario la envíe.	El usuario debe iniciar el chat y autorizar el envío.
Celular directamente	GPS del dispositivo	Requiere una aplicación instalada en el dispositivo objetivo y permisos de localización.	Consentimiento expreso durante la instalación y uso.

9.1. Alcance propuesto

- Prototipo funcional con registro por número telefónico, autenticación y visualización de ubicaciones en un mapa.
- Actualización periódica de la ubicación, con intervalo configurable (por ejemplo, cada 10 minutos).
- Historial de ubicaciones y, como funcionalidad opcional, alertas por geofencing.
- Documentación técnica, modelo de datos, API, plan de pruebas y análisis de riesgos.
- Demostración con datos sintéticos o de laboratorio; no se utilizarán personas reales ni dispositivos de terceros.

9.2. Fuera de alcance

- Rastrear personas sin consentimiento, interceptar comunicaciones o vulnerar la seguridad de WhatsApp, Telegram o de un operador móvil.
- Utilizar APIs no oficiales, ingeniería inversa o técnicas que incumplan los términos de servicio de las plataformas.
- Almacenar datos personales reales, credenciales o ubicaciones de terceros en el repositorio o en el informe.
- Automatizar bloqueos, decisiones disciplinarias o acciones sobre personas a partir de una puntuación de riesgo.

Principio de diseño

La solución debe pedir la ubicación, no tomarla por la fuerza. El usuario objetivo debe conocer quién recibe sus datos, para qué se usan, durante cuánto tiempo se conservan y cómo puede revocar el consentimiento.

10. Requisitos funcionales

La Tabla 28 recoge los requisitos funcionales mínimos del sistema. El equipo debe completar la prioridad, el criterio de aceptación y el estado de implementación.

Tabla 28
Requisitos funcionales de la solución

Código	Requisito	Descripción	Prioridad	Criterio de aceptación
RF-01	Registro por número telefónico	El sistema debe registrar y vincular dispositivos a través del número telefónico.	Alta	
RF-02	Solicitud y captura de ubicación	Permitir al usuario objetivo enviar su ubicación actual o automática.	Alta	
RF-03	Actualización periódica	Capturar la ubicación del dispositivo cada intervalo definido (por ejemplo, cada 10 minutos).	Media	
RF-04	Visualización en mapa	Mostrar la ubicación en un mapa integrado (Google Maps, OpenStreetMap u otro).	Alta	
RF-05	Alertas (opcional)	Alertar si el dispositivo entra o sale de una zona geográfica (geofencing).	Baja	
RF-06	Historial de ubicaciones	Guardar y consultar ubicaciones pasadas por fecha y hora.	Alta	
RF-07	Acceso seguro	Autenticar al usuario y autorizar el acceso a las ubicaciones propias o compartidas.	Alta	

11. Requisitos técnicos

La solución se compone de una aplicación móvil, un bot opcional, un backend con API REST, una base de datos y una capa de visualización. La Tabla 29 resume los componentes y las tecnologías sugeridas.

Tabla 29
Componentes técnicos y tecnologías sugeridas

Componente	Requisito técnico	Tecnología sugerida	Versión	Estado
Aplicación móvil	Captura GPS y envío periódico de coordenadas.	Android/iOS nativo o Flutter/React Native.		
Bot de Telegram	Solicitud manual de ubicación y autorización del usuario.	Bot API de Telegram.		
Backend	API REST para registrar usuarios y recibir ubicaciones.	Python, Node.js, PHP o similar.		
Base de datos	Persistencia de usuarios, dispositivos, ubicaciones y consentimientos.	PostgreSQL, MongoDB o Firebase.		
Autenticación	Registro y acceso por número y token.	JWT, OAuth 2.0 o sesiones seguras.		
Mapa	Visualización y geocodificación inversa.	Google Maps, Mapbox o Leaflet.js.		

11.1. Aplicación móvil

- Aplicación Android/iOS instalada en el dispositivo objetivo.
- Solicitud de permisos de GPS y localización en el momento de la instalación o del primer uso.
- Envío periódico de coordenadas al servidor (backend).
- Vinculación con el número telefónico mediante SMS o código de verificación.
- Indicador visible de que la ubicación se está compartiendo y opción de detenerla.

11.2. Bot en Telegram (opcional)

- El bot puede solicitar la ubicación manual mediante botones.
- No puede rastrear automáticamente sin que el usuario envíe su ubicación.
- Requiere que el usuario inicie el chat y autorice el envío.
- El bot debe informar la finalidad, el tiempo de retención y la forma de revocar el consentimiento.

11.3. Backend y API REST

- Lenguaje: Python, Node.js, PHP o similar.

- API REST para enviar y recibir ubicaciones, con versionado y documentación OpenAPI.
- Base de datos: PostgreSQL, MongoDB o Firebase.
- Sistema de autenticación por número y token, con expiración y revocación.
- Registros de auditoría para accesos, consultas y cambios de consentimiento.

11.4. Mapa y visualización

- API de Google Maps, Mapbox o Leaflet.js para mostrar las ubicaciones.
- Soporte para geocodificación inversa (coordenadas a dirección).
- Marcas con fecha y hora, historial por intervalo y control de acceso por usuario.

11.5. Requisitos de seguridad y privacidad

Tabla 30
Requisitos de seguridad y privacidad de la solución

Código	Requisito	Implementación propuesta	Verificación
RS-01	Cifrado en tránsito	TLS 1.2 o superior en todas las comunicaciones con la API y el bot.	
RS-02	Protección de credenciales	Hash de contraseñas con Argon2, bcrypt o scrypt; nunca almacenar texto claro.	
RS-03	Sesiones y tokens	Tokens con expiración, rotación y revocación; almacenamiento seguro en el cliente.	
RS-04	Control de acceso	Cada usuario solo puede consultar sus dispositivos y ubicaciones autorizadas.	
RS-05	Limitación de tasa	Límites por usuario, dispositivo e IP para evitar abuso y enumeración.	
RS-06	Validación de entradas	Validar y normalizar números, coordenadas, fechas y parámetros de la API.	
RS-07	Cifrado en reposo	Cifrar la base de datos y las copias de seguridad; gestionar claves fuera del código.	
RS-08	Auditoría	Registrar accesos, consultas, cambios de consentimiento y errores de seguridad.	
RS-09	Consentimiento	Registro explícito, fecha, alcance, finalidad y revocación del consentimiento.	
RS-10	Minimización y retención	Recolectar solo los datos necesarios y definir plazos de conservación y borrado.	

12. Arquitectura de referencia

La arquitectura de referencia separa la captura de ubicación, la autenticación, el almacenamiento y la visualización. La Figura 16 es un espacio para que el equipo incluya su diagrama; la Tabla 31 describe las responsabilidades de cada componente.



Figura 16
Arquitectura de referencia de la solución

Tabla 31
Componentes de la arquitectura y responsabilidades

Componente	Función	Entrada	Salida	Tecnología
Aplicación móvil	Captura y envía la ubicación con consentimiento.	GPS, usuario	Coordenadas, estado	
Bot de Telegram	Solicita la ubicación de forma manual.	Comando del usuario	Coordenadas	
API REST	Valida, autentica y registra las solicitudes.	Peticiones HTTPS	Respuestas JSON	
Autenticación	Verifica identidad y permisos.	Número, token	Sesión / JWT	
Base de datos	Persiste usuarios, dispositivos, ubicaciones y consentimientos.	Datos validados	Consultas	
Servicio de mapas	Representa las ubicaciones y resuelve direcciones.	Coordenadas	Mapa / dirección	
Panel administrativo	Consulta y audita el sistema.	Credenciales	Reportes	

13. Modelo de datos propuesto

La Tabla 32 propone las entidades mínimas. El equipo debe ajustar los campos a su implementación y documentar las claves primarias, foráneas e índices.

Tabla 32
Entidades y campos principales del modelo de datos

Entidad	Campos principales	Relaciones
Usuario	Identificador, nombre, número telefónico, correo, hash de contraseña, estado.	Uno a muchos con dispositivos y consentimientos.
Dispositivo	Identificador, usuario, número, plataforma, token, estado.	Muchos a uno con usuario; uno a muchos con ubicaciones.
Ubicación	Identificador, dispositivo, latitud, longitud, precisión, fecha/hora, fuente.	Muchos a uno con dispositivo.
Consentimiento	Identificador, usuario, finalidad, alcance, fecha, estado, fecha de revocación.	Muchos a uno con usuario.
Zona	Identificador, usuario, nombre, centro, radio.	Uno a muchos con alertas.
Alerta	Identificador, zona, dispositivo, tipo, fecha, estado.	Muchos a uno con zona y dispositivo.

14. Plan de trabajo

El plan de la Tabla 33 distribuye las tres semanas del taller. Ajuste las fechas y los responsables según la disponibilidad del equipo; conserve los hitos de revisión y la entrega final.

Tabla 33
Plan de trabajo sugerido

Semana	Fechas	Actividades	Entregable	Responsable
1	26 oct – 1 nov	Marco del laboratorio, topología, casos 1 a 3 y diseño inicial de la Parte II.	Fichas 1–3 y propuesta inicial.	
2	2 – 8 nov	Casos 4 a 7, arquitectura, modelo de datos y API.	Fichas 4–7 y arquitectura.	
3	9 – 14 nov	Casos 8 a 10, implementación, pruebas, informe final y hashes.	Versión final y anexos.	

15. Entregables de la Parte II

- ☐ Código fuente funcional en un repositorio con historial de commits.
- ☐ README con requisitos, instalación, configuración, ejecución y pruebas.
- ☐ Diagrama de arquitectura y modelo de datos.

- [ ] Documentación de la API REST (OpenAPI o equivalente).
- [ ] Demostración con datos sintéticos o de laboratorio (video, capturas o ejecución en vivo).
- [ ] Plan de pruebas y resultados de los casos felices y de error.
- [ ] Política de privacidad, consentimiento informado y mecanismo de revocación.
- [ ] Análisis de riesgos, limitaciones y trabajo futuro.

16. Consideraciones éticas, legales y de privacidad

El diseño y la implementación de la solución deben cumplir los principios de consentimiento, finalidad, minimización, seguridad y transparencia. En Colombia, el tratamiento de datos personales se rige, entre otras normas, por la Ley 1581 de 2012 (Congreso de la República de Colombia, 2012). La ubicación geográfica es un dato personal y su tratamiento requiere autorización previa, expresa e informada del titular, salvo las excepciones legales.

16.1. Principios de tratamiento

- **Consentimiento informado:** el usuario debe conocer quién recibe la ubicación, para qué, durante cuánto tiempo y cómo revocar la autorización.
- **Finalidad limitada:** los datos solo se usan para el propósito académico declarado; no se reutilizan para marketing, vigilancia o perfilamiento.
- **Minimización:** se recolectan únicamente los datos necesarios; se evita la ubicación continua cuando basta una captura periódica.
- **Seguridad:** TLS en tránsito, cifrado en reposo, control de acceso, tokens con expiración y registros de auditoría.
- **Retención y borrado:** se define un plazo de conservación y un mecanismo de eliminación verificable.
- **Transparencia:** el usuario puede consultar qué datos se almacenan, corregirlos y solicitar su eliminación.

- **No discriminación:** la ubicación no se usa para tomar decisiones automatizadas sobre personas.

16.2. Prohibiciones explícitas

- Rastrear a una persona sin su consentimiento o mediante engaño, coerción o suplantación.
- Interceptar comunicaciones, vulnerar plataformas o usar APIs no oficiales.
- Compartir ubicaciones con terceros no autorizados o publicarlas en el repositorio.
- Usar los datos para vigilar, acosar, discriminar o tomar represalias.
- Delegar en un modelo de IA la decisión de bloquear, sancionar o exponer a una persona.

Nota del taller

El taller no solicita vulnerar, atacar ni hackear escenarios domésticos o empresariales reales. El ejercicio es académico y los participantes deben actuar como profesionales de seguridad: sin causar daño intencional a sistemas, redes o personas, y sin usar técnicas que comprometan la integridad de sistemas reales sin autorización expresa de sus propietarios.

16.3. Matriz de riesgos éticos y legales

Tabla 34
Riesgos éticos y legales de la solución

Riesgo	Impacto	Medida de mitigación
Rastreo sin consentimiento	Alto	Consentimiento explícito, registro de fecha y revocación; bloqueo del servicio sin autorización.
Exposición de ubicaciones	Alto	Cifrado, control de acceso, minimización y auditoría de consultas.
Uso secundario de los datos	Medio	Política de finalidad limitada y prohibición de reutilización.
Retención excesiva	Medio	Plazo de conservación definido y borrado programado.
Acceso no autorizado	Alto	Autenticación fuerte, tokens con expiración y principio de mínimo privilegio.
Sesgo o error del modelo	Medio	Revisión humana, métricas de falsos positivos y explicabilidad.

17. Conclusiones

Las conclusiones deben sintetizar los hallazgos, reconocer las limitaciones de la evidencia y proponer un plan de mejora priorizado. No repita el procedimiento de cada caso: interprete qué demuestra la evidencia, qué no demuestra y qué control reduce el riesgo.

Tabla 35
Síntesis de hallazgos y controles por caso

Caso	Hallazgo principal	Evidencia que lo sustenta	Control recomendado	Limitación
1				
2				
3				
4				
5				
6				
7				
8				
9				
10				

17.1. Conclusiones de la Parte I

[Redacte entre tres y cinco párrafos. Indique qué patrones se repitieron entre casos, qué controles tuvieron mayor impacto y qué indicadores resultaron más fiables. Diferencie los hallazgos confirmados de las hipótesis no resueltas.]

17.2. Conclusiones de la Parte II

[Explique qué solución se propuso, por qué es viable, qué requisitos de seguridad y privacidad se priorizaron y qué límites tiene el prototipo. Diferencie el rastreo con consentimiento del rastreo encubierto y justifique por qué este último queda fuera del alcance.]

17.3. Limitaciones y trabajo futuro

- **Limitaciones de la evidencia:** tamaño de las capturas, tráfico sintético, ausencia de algunos registros, relojes no sincronizados o datos anonimizados que impiden reproducir el contexto.
- **Limitaciones del prototipo:** cobertura de dispositivos, precisión del GPS, disponibilidad de APIs, consumo de batería y dependencia de servicios de terceros.

- **Trabajo futuro:** ampliar la línea base, automatizar la correlación con reglas explicables, evaluar la deriva del modelo, incorporar pruebas de carga y mejorar los mecanismos de consentimiento y borrado.

Referencias

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer Security Incident Handling Guide* (Special Publication N.º 800-61 Rev. 2). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/61/r2/final

Congreso de la República de Colombia. (2012). Ley 1581 de 2012, por la cual se dictan disposiciones generales para la protección de datos personales. https://www.funcionpublica.gov.co/eva/gestornormativo/norma.php?i=49981

Mockapetris, P. (1987). Domain Names—Implementation and Specification. https://doi.org/10.17487/RFC1035

OWASP Foundation. (2021). OWASP Top 10:2021—The Ten Most Critical Web Application Security Risks. https://owasp.org/Top10/

Postel, J. (1981). Internet Control Message Protocol. https://doi.org/10.17487/RFC0792

Rescorla, E. (2018). The Transport Layer Security (TLS) Protocol Version 1.3. https://doi.org/10.17487/RFC8446

Saint-Andre, P. (2011). Extensible Messaging and Presence Protocol (XMPP): Core. https://doi.org/10.17487/RFC6120

Scarfone, K., Jansen, W., & Tracy, M. (2008). *Guide to General Server Security* (Special Publication N.º 800-123). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/123/final

Scarfone, K., & Mell, P. (2007). *Guide to Intrusion Detection and Prevention Systems (IDPS)* (Special Publication N.º 800-94). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/94/final

Scikit-learn developers. (2026). Scikit-learn: Machine Learning in Python. https://scikit-learn.org/stable/

Wireshark Foundation. (2026). Wireshark User's Guide. https://www.wireshark.org/docs/wsug_html_chunked/

Anexos

Anexo A. Registro de evidencias y cadena de custodia

Conserve la evidencia original sin modificaciones y analice una copia de trabajo. Registre el hash SHA-256 de la copia original antes de abrirla con cualquier herramienta de análisis.

Tabla 36

Registro de evidencias y cadena de custodia

Archivo	Tipo	Tamaño	Fecha/hora	`SHA-256`	Analista

Anexo B. Lista de verificación de entrega

Tabla 37
Lista de verificación de entrega

Entregable	¿Incluido?	Observaciones	Responsable
Informe técnico con resumen ejecutivo y alcance.	☐		
Diez fichas de caso completas.	☐		
Capturas legibles y PCAP de laboratorio.	☐		
Hashes SHA-256 y cadena de custodia.	☐		
Reglas de detección propuestas.	☐		
Conclusiones y limitaciones.	☐		
Código fuente y README de la Parte II.	☐		
Diagrama de arquitectura y modelo de datos.	☐		
Demostración con datos sintéticos.	☐		
Política de privacidad y consentimiento.	☐		

Anexo C. Glosario

Tabla 38
Términos frecuentes del taller

Término	Definición
Anomalía	Desviación observable respecto de una línea base o comportamiento esperado.
E2EE	Cifrado de extremo a extremo: solo los participantes pueden leer el contenido.
Falso positivo	Alerta que señala un comportamiento legítimo como si fuera malicioso.
Geofencing	Definición de una zona geográfica y generación de alertas al entrar o salir de ella.
Hash SHA-256	Huella digital de 256 bits que permite verificar la integridad de un archivo.
IDS / IPS	Sistema de detección / prevención de intrusiones.
IOC	Indicador de compromiso: señal observable que sugiere actividad maliciosa.
MITM	Ataque de intermediario que intercepta o modifica una comunicación.
PCAP	Archivo de captura de paquetes de red.
SIEM	Plataforma de correlación y gestión de eventos e incidentes de seguridad.
TLS	Protocolo de seguridad para el transporte de datos en red.